

ORION FINANCIAL TECHNOLOGIES

Enterprise Platform Governance Strategy Blueprint

Platform Engineering | SOX Section 404 and ISO/IEC 27001:2022

Attribute	Value	Attribute	Value
Document Owner	Lead Platform Engineer	Classification	Internal - Audit Evidence
Approving Authority	Head of Platform Engineering	Version	1.0 (Baseline)
Audit Scope	SOX 404 ITGC; ISO 27001 Annex A	Review Cadence	Semi-annual

This blueprint is the definitive control reference for engineering team leads across the Orion platform estate. It defines the identity boundaries, source control integrity requirements, ephemeral compute governance, and GenAI assurance layers that evidence internal control over financial reporting and information security management.

Section 1: Organizational Hierarchy and Access Architecture (Azure DevOps)

The Azure DevOps estate operates as a single organization bound to the corporate Microsoft Entra ID tenant, eliminating the unmanaged boundaries that previously permitted privilege bleeding between delivery teams. Authorization inherits strictly downward through three tiers, and no principal holds permissions outside its assigned tier.

1.1 Three-Level Permissions Matrix

Tier	Scope	Entra ID Group	Azure DevOps Role	Segregation Constraint
Tier 1	Organization	ORG-ADO-PlatformOwners	Project Collection Administrator	Break-glass only; two named holders; four-hour PIM activation with justification
Tier 2	Core Projects (Payments, Ledger, Client Portal)	PRJ-<project>-Admins	Project Administrator	Cannot modify organization policy, pool authorization, or audit streaming
Tier 3	Product Teams	TEAM-<team>-Contributors / -Readers	Contributor / Reader	No permission delegation, environment approval rights, or pool administration
Control	Release authorization	SEG-Release-Approvers-<domain>	Environment Approver only	Membership mutually exclusive from Tier 3 contributors of the same product

1.2 Entra ID Role-Based Access Control Mapping

- All Azure DevOps groups are populated exclusively by Entra ID security groups; direct user membership is blocked by policy.
- Tier 1 and environment approver roles are governed by Privileged Identity Management, requiring justification, sign-off, and time-bound activation.

- Joiner-mover-leaver events are driven by HR lifecycle workflows, with deprovisioning completed within 24 hours of termination.
- Quarterly access reviews are attested by the named control owner; unattested memberships are automatically revoked.

1.3 Pipeline Environment Approvals and Stage-Gate Locks

Every production environment enforces multi-party approval. At least two approvers from the segregated approver group must authorize promotion, and self-approval by the run requester is disabled. Stage gates additionally apply an exclusive lock to serialize deployments, a branch control check restricting deployment to signed tags on the protected trunk, and a change-record check that fails the stage where no approved ticket exists.

1.4 Global Agent Pool Partitioning

Agent pools are partitioned by regulatory domain. Payments and ledger workloads execute on dedicated pools never shared with non-regulated products. Open access for all pipelines is disabled organization-wide, so each pipeline is individually authorized against a pool, and each pool authenticates to Azure through a scoped managed identity with no standing subscription rights.

1.5 Audit Trail Integrity

Azure DevOps auditing streams continuously to Log Analytics and to an immutable storage account under a seven-year time-based WORM retention policy. Platform administrators hold read-only rights over that store and cannot delete, alter, or shorten retention on any record. Detection rules alert on permission escalation, policy modification, pool authorization changes, and disabled approval checks, providing the tamper-evident record required by SOX Section 404 and ISO 27001 Annex A 8.15.

Section 2: Repository Integrity and Branch Governance Framework (GitHub Enterprise)

Source control operates on a trunk-based development model. A single protected trunk represents releasable state at all times, feature branches must merge or close within 72 hours, and incomplete functionality is isolated behind feature flags rather than long-running integration branches.

2.1 Organization-Level Repository Rule Set

Control	Enforced Configuration	Control Objective
Linear history	Merge commits blocked; squash or rebase only	Deterministic, reconstructable change sequence
Required reviewers	Two approvals; stale approvals dismissed on new commits; self-approval blocked	Segregation of duties on every change
CODEOWNERS enforcement	Owner review mandatory; pipeline, IaC, and workflow paths owned by Platform Engineering	Accountable technical authority per domain
Commit signing	GPG or SSH signature required and verified on all commits	Cryptographic non-repudiation of authorship
Vigilant Mode	Enabled organization-wide; unverified commits visibly flagged	Prevents author spoofing
Administrator bypass	Bypass list empty; owners and admins cannot override	No privileged circumvention of review gates
Required status checks	Build, SAST, IaC policy scan, and GenAI advisory scan	Automated quality and security assurance

Control	Enforced Configuration	Control Objective
Push protection	Force push and branch deletion blocked; secret scanning push protection enabled	Preserves immutable history

2.2 Repository Analytics and Clone-Time Optimization

Repository health is measured through GitHub Insights and job telemetry, with object count, pack size, and median checkout duration published to a platform dashboard. A 50% reduction in median clone time against the current baseline is the committed target, delivered through:

- Migration of binary artifacts and test fixtures to Git LFS, removing large blobs from the default fetch path.
- Blobless partial clones and sparse checkout in CI, fetching only the trees and paths a job requires.
- Scheduled repacking and commit-graph maintenance, plus retirement of stale branches and tags.
- Progressive extraction of independently deployable services from the monorepo where coupling permits.

2.3 Compliance Alignment

Mandatory signing and Vigilant Mode establish verified identity for every change, satisfying ISO 27001 identity and authentication objectives. Dual review, CODEOWNERS, disabled administrator bypass, and immutable linear history together produce the authorization evidence and traceability that SOX Section 404 requires of program change controls.

Section 3: Ephemeral Infrastructure and Runner Fleet Scaling (GitHub Actions and AKS)

Self-hosted capacity is delivered by Actions Runner Controller scale sets on private Azure Kubernetes Service clusters. Runners are ephemeral: each pod services exactly one job and is destroyed on completion, eliminating state carry-over. Authentication to GitHub uses federated workload identity, so no long-lived tokens exist in the fleet.

3.1 Terraform Governance and Scaling Envelope

All clusters, node pools, and runner scale sets are provisioned exclusively through versioned Terraform modules with remote state, locking, and policy-as-code validation. Helm values, including minRunners and maxRunners, are rendered by Terraform rather than applied manually; direct kubectl or Helm intervention is prohibited and a nightly plan detects drift. Node boundaries are declared per team through taints, labels, and bounded autoscaler counts.

Parameter	Non-Production	Regulated Production	Rationale
minRunners	2	6	Warm capacity absorbing burst arrival without cold start
maxRunners	40	120	Upper bound protecting subscription quota and cost
Node pool autoscaler	2 to 20 nodes	6 to 40 nodes	Bounded elasticity per isolated team pool
Scale-out trigger	Queue depth above 5 for 60 seconds	Queue depth above 3 for 30 seconds	Queue depth is the primary demand indicator
Scale-in cooldown	10 minutes	15 minutes	Prevents oscillation across staggered release windows

Node headroom is held by low-priority placeholder pods so scale-out schedules onto pre-warmed capacity, and runner images are pre-pulled by a DaemonSet to remove pull latency from the critical path.

3.2 Prometheus Telemetry and Performance Thresholds

Managed Prometheus scrapes controller and listener metrics, pod scheduling latency, and a workflow exporter that classifies failure signatures. Recording rules and alerts enforce the committed service levels:

Monitored Signal	Threshold	Automated Response
Pipeline queue latency (p95)	Below 30 seconds	Page platform on-call; raise minRunners floor
Runner pod provisioning delay (mean)	Below 45 seconds	Investigate node headroom and image cache hit rate
Runner cluster queue depth	Sustained depth above 10	Trigger scale-out and review the maxRunners ceiling
Workflow failure signature rate	Below 5% per signature class	Route to owning team with classified failure evidence

Metrics are retained for 400 days, giving auditors a continuous capacity record across the full reporting period.

Section 4: GenAI-Assisted Governance and Policy Verification

4.1 Automated Workflow Risk Advisory

A required advisory step executes on every pull request that modifies workflow definitions. A large language model analyses the proposed YAML for execution-context risks before merge, including interpolation of untrusted event data into shell steps that enables script injection, unsafe use of privileged pull request triggers, third-party actions not pinned to an immutable commit SHA, excessive token permissions, and self-hosted label misuse that could route untrusted code onto regulated pools. Findings post as structured review comments with severity and remediation guidance.

4.2 Infrastructure-as-Code Drift Detection

The same service compares proposed Terraform and Helm changes against the approved governance corpus, comprising this blueprint, the baseline module library, and the identity naming standard. Deviations indicating access-control drift are flagged against the control they contravene, for example wildcard role assignments, re-enabled open pool access, disabled signature requirements, or scaling parameters outside the sanctioned envelope. Each finding is emitted as a structured record attached to the change ticket as review evidence.

4.3 Data Protection Boundaries

- Inference runs on a tenant-scoped Azure OpenAI deployment over a private endpoint, with no public egress from the analysis runner.
- Zero data retention and abuse-monitoring exclusion are contractually enforced; no prompt, completion, or diff reaches model training or provider-side review.
- Prompt assembly is limited to the changed diff and passes through secret detection and redaction; credentials, customer data, and production telemetry are never transmitted.

- Prompts and responses are logged to the same immutable audit store as platform events, under a completed data protection impact assessment and supplier risk review.

4.4 Augmentation, Not Replacement

The advisory service holds no approval authority. It belongs to no approver group, cannot satisfy a CODEOWNERS requirement, cannot approve a pull request, and operates with a read-only token. Deterministic tooling remains the blocking gate; model output is advisory only. High-severity findings require a recorded human disposition before merge, and the named human reviewer remains the accountable party in every audit record.

Section 5: Governance Summary and Audit Readiness Statement

The four control layers form a single enterprise security perimeter rather than independent safeguards. Entra ID hierarchies establish who may act and within which boundary; repository rule sets ensure every change entering the trunk is reviewed, cryptographically attributed, and immutably recorded; Terraform-governed AKS fleets guarantee that only sanctioned, ephemeral infrastructure executes that change under continuous telemetry; and the GenAI advisory layer inspects the workflow and infrastructure definitions themselves before merge. Identity constrains authorization, source control constrains change, infrastructure constrains execution, and automated review constrains configuration drift, with immutable evidence produced at each boundary.

5.1 Audit Readiness Statement

Orion Financial Technologies asserts that the controls documented in this blueprint are designed and operating to satisfy the objectives below, evidenced entirely through system-generated artefacts available for independent inspection.

Control Domain	Implementing Control	SOX Section 404 Objective	ISO 27001 Reference
Access architecture	Three-tier matrix, Entra ID RBAC, PIM activation, quarterly attestation	Access provisioning and segregation of duties	A.5.15, A.5.16, A.5.18, A.8.2
Change management	Rule sets, dual review, CODEOWNERS, verified signing	Authorized and traceable program change	A.8.28, A.8.32
Release authorization	Multi-party environment approvals, stage-gate locks, branch control	Segregation of duties in deployment	A.5.3, A.8.32
Infrastructure integrity	Terraform-managed AKS and ARC, partitioned pools, drift detection	Configuration and computing resource integrity	A.8.9, A.8.31
Monitoring and logging	Immutable audit store, Prometheus telemetry, escalation alerting	Ongoing monitoring of IT general controls	A.8.15, A.8.16
GenAI assurance	Advisory scanning under enforced data boundaries	Supporting evidence of control effectiveness	A.5.23, A.8.28

5.2 Active Risk Monitoring Log

ID	Risk of Drift	Leading Indicator	Long-Term Mitigation
R-01	Identity group sprawl as teams subdivide, eroding least-privilege boundaries	Group count growth above 10% per quarter; groups with no active members	Entra groups provisioned only through Terraform against an enforced naming standard; dormant groups expire after 90 days; attested quarterly reviews
R-02	Monorepo bloat degrading clone performance and review granularity	Pack size growth; median clone time regression against baseline	Repository size budget enforced in CI; continued LFS and partial clone adoption; phased extraction of deployable services
R-03	Runner fleet capacity and cost drift during peak release windows	Sustained maxRunners saturation; queue latency nearing the 30-second threshold	Quarterly recalibration of scaling envelopes against telemetry; per-team chargeback; capacity review before each release freeze
R-04	Over-reliance on GenAI advisory output in place of human scrutiny	Rising suppression of advisory findings without recorded disposition	Deterministic blocking checks retained independently; quarterly sampled audit of dispositions; advisory precision reported to the control owner

This blueprint is reviewed semi-annually by the Lead Platform Engineer and approved by the Head of Platform Engineering. Material control changes require an approved change record and a revision to this document prior to implementation.